

《软件安全》实验报告

姓名：谢小珂 学号：2310422 班级：1069

实验名称：

WEB 开发实践

实验要求：

复现课本第十章的实验三(10.3.5 节):利用 php, 编写简单的数据库插入、查询和删除操作的示例。基于课本的完整例子, 进一步了解 WEB 开发的细节

实验过程：

1. PHPnow 环境搭建

使用 WindowsXP 系统进行本次实验, 安装 PHPnow。选择 PHPnow 的 Apache2.0.63 和 Mysql5.0.90 版本。



设置 MySQL root 密码为 123456 并完成安装。



打开默认界面 (http://127.0.0.1/index.php) 。

127.0.0.1
Let's PHP now !

为何只能本地访问?
此服务器互联网 IP
221.238.245.54

Server Information	
SERVER_NAME	127.0.0.1
SERVER_ADDR:PORT	127.0.0.1:80
SERVER_SOFTWARE	Apache/2.0.63 (Win32) PHP/5.2.14
PHP_SAPI	apache2handler
php.ini	C:\PHPnow-1.5.6\php-5.2.14-Win32\php-apache2handler.ini
网站主目录	C:/PHPnow-1.5.6/htdocs
Server Date / Time	2025-05-15 14:49:38 (408:00)

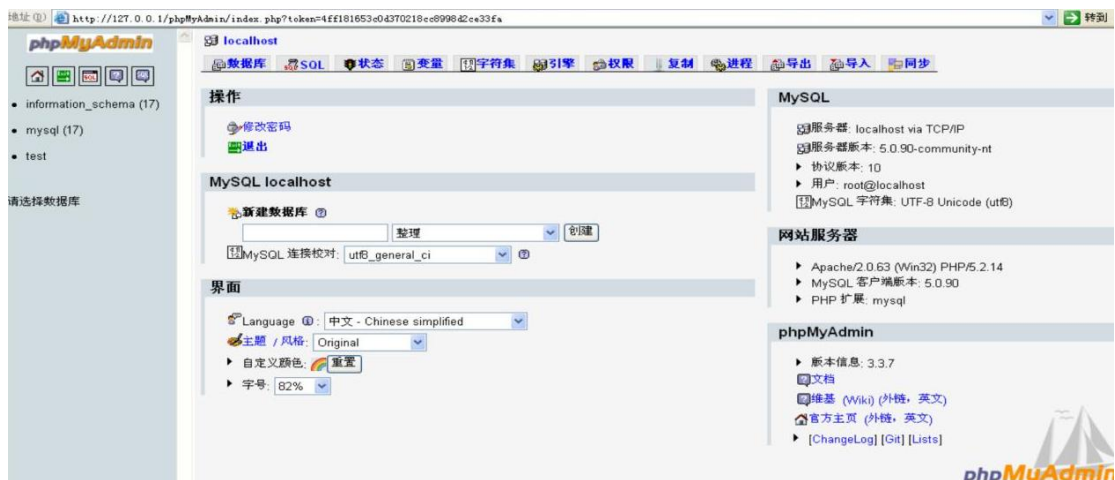
Other Links phpinfo() phpMyAdmin			
PHP 组件支持			
Zend Optimizer	Yes / 3.3.3		
MySQL 支持	Yes / client lib version 5.0.90		
GD library	Yes / bundled (2.0.34 compatible)		
eAccelerator	No		
MySQL 连接测试			
MySQL 服务器	localhost	MySQL 数据库名	test
MySQL 用户名	root	MySQL 用户密码	
			连接

Valid XHTML 1.0 Strict / [Copyleft](#) ! 2007-? by PHPnow.org

输入密码 123456 检查数据库连接是否正常。

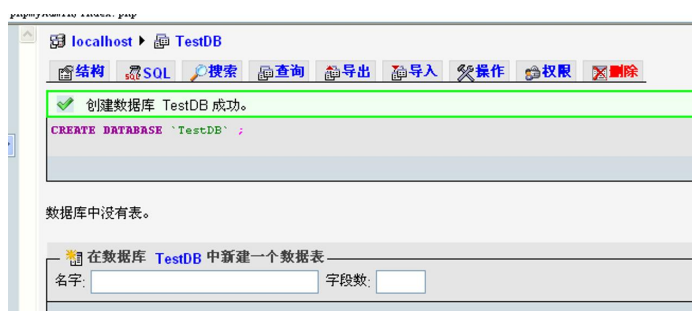
MySQL 连接测试			
MySQL 服务器	localhost	MySQL 数据库名	test
MySQL 用户名	root	MySQL 用户密码	
			连接
MySQL 测试结果			
服务器 localhost	OK (5.0.90-community-nt)		
数据库 test	OK		

点击 phpMyAdmin 进入数据库管理系统，验证数据库连接，确保 PHP 支持 MySQL 组件。



2. PHP 实现数据库基本操作 (增删查) 示例

创建数据库 TestDB。



在数据库中创建数据表 News (newsid, topic, content)。

localhost ▶ testDB ▶ news

字段	newsid	topic	content
类型	INT	VARCHAR	TEXT
长度/值 ¹		50	
默认 ²	无	无	无
整理			
属性			
空	☐	☐	☐
索引	PRIMARY	---	---
AUTO_INCREMENT	☐	☐	☐
注释			

表 userinfo (username, password)。

localhost ▶ testDB ▶ userinfo

字段	username	password
类型	VARCHAR	VARCHAR
长度/值 ¹	30	30
默认 ²	无	无
整理		
属性		
空	☐	☐
索引	PRIMARY	---
AUTO_INCREMENT	☐	☐
注释		

创建成功！

localhost ▶ testdb ▶ userinfo

浏览 结构 SQL 搜索 插入 导出 导入 操作 清空 删除

创建数据表 'testdb`.`userinfo` 成功。

```
CREATE TABLE `testdb`.`userinfo` (
  `username` VARCHAR( 30 ) NOT NULL ,
  `password` VARCHAR( 30 ) NOT NULL ,
  PRIMARY KEY ( `username` )
) ENGINE = MYISAM ;
```

	字段	类型	整理	属性	空	默认	额外	操作
☐	username	varchar(30)	latin1_swedish_ci		否	无		
☐	password	varchar(30)	latin1_swedish_ci		否	无		

全选 / 全不选 选中项:

打印预览 规划表结构

添加 1 个字段 于表结尾 于表开头 于之后 username 执行

插入管理员数据: username=admin, password=admin。



创建 HTML 页面模板，准备编写 html 代码，为后续嵌入 PHP 脚本做准备。



3. html 以及 php 代码编写

3.1 login.html:

```
<html>
<body>
<form id="form1" name="form1" method="post" action="loginok.php"> <table width="900"
border="0" cellspacing="0" cellpadding="0">
<tr> <td height="20">username</td>
<td height="20"><label>
<input name="username" type="text" id="username" />
</label></td>
</tr>
<tr>
<td height="20">password</td>
<td height="20"><label>
<input name="pwd" type="password" id="pwd" />
</label></td>
</tr>
```

```

<tr>
<td height="20"> </td>
<td height="20"><label>
<input type="submit" name="Submit" value="提交" /> </label></td>
</tr>
</table>
</form>
</body>
</html>

```

表单<form>：这个表单的 ID 是 form1，用于创建一个用户登录页面，包含姓名（用户名）和口令（密码）输入框，以及一个提交按钮，并且使用 POST 方法将数据发送到 loginok.php。POST 方法通常用于提交需要处理的数据，比如登录信息。loginok.php 是一个 PHP 文件，用来处理提交的数据。

1>用户名输入框

类型：文本输入框(text)

属性：name="username" id="username"

功能：接收用户输入的用户名信息

2>密码输入框

类型：密码输入框(password)

属性：name="pwd" id="pwd"

特性：输入内容自动隐藏显示

功能：安全接收用户密码

3>提交按钮

类型：表单提交按钮(submit)

显示文本："提交"

行为：触发表单数据提交

提交方式：POST 方法

处理页面：loginok.php

3.2 Loginok.php:

```

<?php
$loginok=0;
$conn=mysql_connect("localhost", "root", "123456");
$username = $_POST['username'];
$pwd = $_POST['password'];
$SQLStr = "SELECT * FROM userinfo where username='$username' and pwd='$pwd'";
echo $SQLStr;
$result=mysql_db_query("testDB", $SQLStr, $conn);
if ($row=mysql_fetch_array($result))//通过循环读取数据内容
{
$loginok=1;

```

```

}
// 释放资源
mysql_free_result($result);
// 关闭连接
mysql_close($conn);
if ($loginok==1)
{
?>

<script>
alert("login succes");
window.location.href="sys.php";
</script>
<?php
}
else{?>
<script>
alert("login failed");
history.back();
</script>
<?php
}
?>

```

这段 PHP 代码实现了一个基础的登录验证功能，通过接收用户输入的用户名和密码，与数据库中的记录进行比对验证：首先建立 MySQL 数据库连接，然后获取并处理表单提交的登录凭证，构建 SQL 查询语句检查用户信息是否存在，验证成功则跳转至系统页面并提示 login success，失败则返回登录页并提示 login failed，最后释放数据库资源完成整个认证流程。



3.3 sys.php:

```

<html xmlns="http://www.w3.org/1999/xhtml">
<head>
<meta http-equiv="Content-Type" content="text/html; charset=gb2312" />
<title>主页</title>
</head>
<?php
$conn=mysql_connect("localhost", "root", "123456");
?>
<body>
<div align="center">
<table width="900" border="0" cellspacing="0" cellpadding="0">

```

```

<tr>
<td height="40"><form id="form1" name="form1" method="post" action="add.php">
<div align="right">新闻标题:
<input name="topic" type="text" id="topic" size="50" />
<BR>
新闻内容:
<textarea name="content" cols="60" rows="8" id="content"></textarea><BR>
<input type="submit" name="Submit" value="添加" />
</div>
</form>
</td>
</tr>
<tr>
<td><hr /></td>
</tr>
<tr>
<td height="300" align="center" valign="top"><table width="600" border="0" cellspacing="0" cellpadding="0">
<tr>
<td width="100" height="30"><div align="center">新闻序号</div></td>
<td><div align="center">新闻标题</div></td>
<td><div align="center">删除</div></td>
</tr><?php
$SQLStr = "select * from news";
$result=mysql_db_query("testDB", $SQLStr, $conn);
if ($row=mysql_fetch_array($result))//通过循环读取数据内容
{
// 定位到第一条记录
mysql_data_seek($result, 0);
// 循环取出记录
while ($row=mysql_fetch_row($result))
{
?>
<tr>
<td height="30"><div align="center"> <?php echo $row[0] ?> </div></td>
<td width="400"> <div align="center"> <?php echo $row[1] ?>
</div></td>
<td><div align="center"><a href="del.php?newsid=<?php echo $row[0] ?> " >
删 除 </a>
</div></td>
</tr>
<?php
}
}

```

```

?>
</table></td>
</tr>
</table>
</div>
</body>
</html>
<?php
// 释放资源
mysql_free_result($result);
// 关闭连接
mysql_close($conn);
?>

```

在页面主体区域，首先设计了一个新闻添加表单。该表单设有两个输入框，分别用于填写新闻标题和新闻内容，以及一个提交按钮。用户填好新闻标题与内容后，点击添加按钮，表单会通过 POST 方式把数据提交到 add.php 文件进行处理。

表单下方是一个展示新闻列表的表格。此表格的数据来源于数据库中的 news 表，会将表中所有新闻记录提取出来。每条新闻在表格里会显示其序号、标题，同时还配有一个删除链接。点击任意删除链接，系统会带着该新闻的 id 参数跳转到 del.php 文件，从而实现新闻删除功能。至此，该部分的框架搭建完毕，效果如图所示。

3.4 news.php:

```

<html>
<head>
<meta http-equiv="Content-Type" content="text/html; charset=gb2312" />
<title>主页</title>
</head>
<body>
<div align="center">
<table width="900" border="0" cellspacing="0" cellpadding="0">
<tr>
<td height="40"><form id="form1" name="form1" method="post" action="loginok.php">
<div align="right">用户名:
<input name="username" type="text" id="username" size="12" />
密码:
<input name="password" type="password" id="password" size="12" />
<input type="submit" name="Submit" value="提交" />
</div>

```

```

</form>
</td>
</tr>
<tr>
<td><hr /></td>
</tr>
<tr>
<td height="300" align="center" valign="top"><p> </p>
<?php
$conn=mysql_connect("localhost", "root", "123456");
$newsid = $_GET['newsid'];$SQLStr = "select * from news where newsid=$newsid";
$result=mysql_db_query("testDB", $SQLStr, $conn);
if ($row=mysql_fetch_array($result))//通过循环读取数据内容
{
// 定位到第一条记录
mysql_data_seek($result, 0);
// 循环取出记录
while ($row=mysql_fetch_row($result))
{
echo "$row[1]<br>";
echo "$row[2]<br>";
}
}
// 释放资源
mysql_free_result($result);
// 关闭连接
mysql_close($conn);
?>
</td>
</tr>
</table>
</div>
</body>
</html>

```

这个新闻详情页面通过解析 URL 中的 newsid 参数，从数据库中动态获取并展示对应新闻的完整内容。页面核心功能由 PHP 脚本实现，通过执行 SQL 查询提取指定新闻的标题和正文，并将其渲染到前端页面中。

3.5 add.php

```

<?php
$conn=mysql_connect("localhost", "root", "123456");
mysql_select_db("testDB");
$topic = $_POST['topic'];
$content = $_POST['content'];

```

```

$SQLStr = "insert into news(topic, content) values('$topic', '$content')";
echo $SQLStr;
$result=mysql_query($SQLStr);
// 关闭连接
mysql_close($conn);
if ($result)
{
?>
<script>
alert("insert succes");
window.location.href="sys.php";
</script>
<?php
}
else{
?>
<script>
alert("insert failed");
history.back();
</script>
<?php
}
?>

```

这段代码通过 PHP 脚本实现新闻添加功能，从表单获取用户输入的新闻标题和内容并插入数据库，根据插入结果显示提示信息，成功则跳转至新闻管理页面，失败则返回输入页面，由 PHP 脚本处理数据库连接、数据插入及结果反馈。

执行结果如下图所示：

新闻序号	新闻标题	删除
1	hello	删除

在表单中填写新闻标题和内容后，点击添加按钮提交数据。若插入操作成功，系统会自动跳转到 sys.php 页面，此时可以看到新添加的新闻已成功显示在列表中。

3.6 del.php

```

<?php
$conn=mysql_connect("localhost", "root", "123456");
mysql_select_db("testDB");
$newsid = $_GET['newsid'];
$SQLStr = "delete from news where newsid=$newsid";echo $SQLStr;
$result=mysql_query($SQLStr);
// 关闭连接

```

```

mysql_close($conn);
if ($result)
{
?>
<script>
alert("delete succes");
window.location.href="sys.php";
</script>
<?php
}
else{
?>
<script>
alert("delete failed");
history.back();
</script>
<?php
}
?>

```

这段 PHP 代码实现了新闻删除功能，原理与添加的原理基本类似，通过以下步骤完成：首先连接本地 MySQL 的 testDB 数据库，从 GET 请求中获取要删除的新闻 ID；然后构造 SQL 删除语句，执行删除 news 表中对应记录的操作并输出 SQL 语句用于调试；操作完成后关闭数据库连接释放资源；最后根据执行结果通过 JavaScript 反馈提示信息，成功则弹出“删除成功”并跳转至 sys.php，失败则弹出“删除失败”并返回上一页。

执行结果如下图所示：



3.7 index.php

```
<html>
```

```

<head>
<meta http-equiv="Content-Type" content="text/html; charset=gb2312" />
<title>主页</title>
</head>
<?php
$conn=mysql_connect("localhost", "root", "123456");
?>
<body>
<div align="center">
<table width="900" border="0" cellspacing="0" cellpadding="0">
<tr>
<td height="40"><form id="form1" name="form1" method="post" action="loginok.php">
<div align="right">用户名:
<input name="username" type="text" id="username" size="12" /> 密码:
<input name="pwd" type="password" id="pwd" size="12" />
<input type="submit" name="Submit" value="提交" />
</div>
</form>
</td>
</tr>
<tr>
<td><hr /></td>
</tr>
<tr>
<td height="300" align="center" valign="top"><table width="600" border="0"
cellspacing="0" cellpadding="0">
<tr>
<td width="100" height="30"><div align="center">新闻序号</div></td>
<td><div align="center">新闻标题</div></td>
</tr>
<?php
$SQLStr = "select * from news";
$result=mysql_db_query("testDB", $SQLStr, $conn);
if ($row=mysql_fetch_array($result))//通过循环读取数据内容
{
// 定位到第一条记录
mysql_data_seek($result, 0);
// 循环取出记录
while ($row=mysql_fetch_row($result))
{
?>
<tr>
<td height="30"><div align="center"> <?php echo $row[0] ?> </div></td>
<td> <div align="center"> <a href="news.php?newsid=<?php echo $row[0] ?>" > <?

```

```

php echo
$row[1] ?> </a> </div></td>
</tr>
<?php
}
}
?>
</table></td>
</tr>
</table>
</div>
</body>
</html>
<?php
// 释放资源
mysql_free_result($result);
// 关闭连接
mysql_close($conn);
?>

```

这个页面整合了用户登录与新闻展示功能，采用传统表格布局实现。页面包含两个核心模块：左侧为登录表单，通过 POST 方法将用户名和密码提交至 loginok.php 处理；右侧为新闻列表区域，通过执行 `SELECT * FROM news` 查询数据库获取所有新闻记录。每条新闻标题均设置为超链接，点击后会携带 `newsid` 参数跳转到 news.php 页面以展示新闻详情。整体设计通过数据库连接实现了动态数据展示与用户交互功能。

用户名: root	密码: *****	提交
--	--	-----------------------------------

新闻序号	新闻标题
1	hello

心得体会：

本次 WEB 开发实践实验通过复现课本案例，让我对 PHP 与数据库交互的全流程有了系统性认知，主要收获如下：

一、技术流程的实践贯通

从搭建 PHPnow 环境（配置 Apache、MySQL 并完成连接测试）到创建数据库表（设计 News、userinfo 表结构），再到编写 HTML 表单与 PHP 脚本实现登录验证、新闻增删查功能，完整经历了从环境搭建到业务逻辑实现的开发链条。例如，通过 `$_POST` 和 `$_GET` 获取用户输入，用 `mysql_query` 执行 SQL 语句，结合 JavaScript 实现页面跳转与提示，清晰理解了前后端数据交互的逻辑。

二、核心能力的提升

数据库操作：掌握了 `SELECT`（查询新闻列表）、`INSERT`（添加新闻）、`DELETE`（删除新闻）的 SQL 语句编写，以及 `mysql_fetch_array` 等函数对查询结果的处理。

调试与排错：通过输出 SQL 语句到页面、检查数据库连接状态等方式，解决了数

据插入失败、页面跳转异常等问题，提升了问题定位能力。

三、安全与规范意识

实验中意识到直接拼接 SQL 语句存在注入风险（如登录验证模块），虽未在本次简化代码中实现预编译等防护措施，但明确了后续开发需重点关注的安全点。同时，及时关闭数据库连接（`mysql_close`）、释放资源（`mysql_free_result`）的操作习惯，强化了代码规范与资源管理意识。

四、实践中的思考

传统表格布局虽能实现功能，但响应式体验不足；MySQL 旧版 API（如 `mysql_connect`）已 deprecated，后续需转向更安全的 `mysqli` 或 `PDO` 扩展。这些待优化点为进一步学习指明了方向。

总结：本次实验以“做中学”的方式，将理论知识转化为可运行的系统，不仅巩固了 PHP 开发基础，更培养了从环境搭建到功能实现的全流程思维，为后续深入学习 WEB 开发奠定了实践基础。